REPUBLIQUE DU CAMEROUN
Paix-Travail-Patrie
*****
MINISTÈRE DE L'ENSEIGNEMENT SUPÉRIEUR
*****
UNIVERSITÉ DE YAOUNDÉ I
*****
ÉCOLE NATIONALESU-PÉRIEURE POLYTECHNIQUE
*****
DÉPARTEMENT DE GÉNIE INFORMATIQUE
*****

REPUBLIC OF CAMEROON
Peace - Work - Fatherland
*****
MINISTRY OF HIGHER EDUCATION
*****
UNIVERSITY OF YAOUNDÉ I
*****
NATIONAL ADVANCED SCHOOL OF ENGINEERING
*****
COMPUTER ENGINEERING DEPARTMENT
*****

Rapport d'Audit — UE : GES4062

ANALYSE DE RISQUE, AUDIT ET GESTION DE CRISE

Gouvernance, Conformité, Résilience et RETEX

Cas fil rouge :

Entreprise LiZbiZ (E-commerce & Logistique)

EBIOS RM · ISO 27001/27005 · ISO 19011 · ISO 22301 · ISO 27035

MAGUENA NDENE Marcel Allan
Université de Yaoundé I — ENSP — Département de Génie Informatique
Année académique 2025–2026

TABLE DES MATIÈRES

1 Pourquoi cette charte ? 4

1.1 Constat 4

1.2 Finalité de cette charte 5

2 Périmètre et valeurs 6

2.1 Ce que cette charte couvre 6

2.2 Nos trois engagements fondamentaux 6

3 Le rssi : rôle, missions et positionnement 7

3.1 Positionnement dans l'organigramme 7

3.2 Les 5 missions du RSSI 7

3.3 Ce que le RSSI ne fait pas 7

4 Les acteurs de la gouvernance 9

4.1 Les 5 acteurs clés 9

4.2 Les instances collectives 9

5 Matrice raci — Gestion des incidents critiques 11

5.1 Rappel du code RACI 11

5.2 Périmètre de la matrice 11

5.3 Matrice RACI — Incidents critiques 11

5.4 Lecture commentée de la matrice 11

6 Actions prioritaires pour LiZbiZ 13

7 Entrée en vigueur et validation 14

7.1 Conditions d'application 14

7.2 Engagements du CODIR 14

7.3 Tableau de validation 14

LISTE DES TABLEAUX

5.1 Matrice RACI — gestion d'un incident critique chez LiZbiZ 12

Champ	Valeur
LiZbiZ SA	Entreprise
Document	Charte de Gouvernance Sécurité SI
Version	1.0 — Document fondateur
Date	Mars 2026
Destinataires	Comité de Direction (CODIR)
Préparée par	Cabinet de Consultants — Mission RSSI intérim
Statut	En attente de validation par le CODIR

« La sécurité n'est ni technique, ni organisationnelle : elle est les deux à la fois. »

1

POURQUOI CETTE CHARTE ?

Objectifs du chapitre

À l'issue de ce chapitre, le lecteur comprendra :

- le contexte de croissance de LiZbiZ et ses conséquences sur la sécurité ;
- les trois lacunes structurelles identifiées par la mission de conseil ;
- la finalité de cette charte comme socle de gouvernance.

LiZbiZ est une entreprise en forte croissance. En deux ans, elle est passée de 20 à 150 salariés, avec un chiffre d'affaires de 45 millions d'euros et une introduction en bourse récente. Cette croissance rapide a eu un effet de bord : la sécurité informatique n'a pas suivi.

1.1 Constat

Attention

Le constat est sans appel : LiZbiZ présente aujourd'hui trois lacunes structurelles majeures en matière de gouvernance de la sécurité.

- Le poste de **RSSI** (Responsable Sécurité SI) est vacant. La DSI cumule ses propres fonctions avec celles de la sécurité, ce qui crée un **conflit d'intérêt** : elle est juge et partie, validant des accès qu'elle crée elle-même.
- Aucun Comité de Sécurité n'existe. La Direction Générale n'est pas informée des risques réels pesant sur le système d'information.
- Les processus de sécurité sont gérés à l'oral. Personne ne sait précisément qui fait quoi en cas d'incident.

Note

Des failles concrètes ont été identifiées lors de la mission préliminaire : mises à jour irrégulières sur le serveur web (VLAN 10), droits d'accès trop larges sur l'ERP Odoo, absence de plan de continuité d'activité (PCA).

1.2 Finalité de cette charte

Dans ce contexte — et alors que des vagues de ransomwares frappent les entreprises du secteur — cette charte pose les bases d'une gouvernance sécurité structurée et lisible par tous les acteurs de LiZbiZ.

Elle ne vise pas l'exhaustivité technique. Elle vise la **clarté des responsabilités** et la **lisibilité des décisions**.

2

PÉRIMÈTRE ET VALEURS

2.1 Ce que cette charte couvre

Cette charte s'applique à l'ensemble du **Système d'Information** (SI) de LiZbiZ, composé des éléments suivants :

- la plateforme e-commerce (Magento 2, VLAN 10) ;
- l'ERP Odoo et les bases de données clients et commandes (PostgreSQL, VLAN 20) ;
- l'infrastructure réseau (switches Cisco, Active Directory, VLAN 99) ;
- les équipements IOT de l'entrepôt automatisé (VLAN 40).

Elle concerne **tous les collaborateurs** de LiZbiZ, qu'ils soient au siège ou en télétravail, ainsi que les prestataires et partenaires ayant accès au SI.

2.2 Nos trois engagements fondamentaux

Valeur	Principe	Ce que ça veut dire concrètement Alignement
La sécurité au service du business	Les mesures de sécurité ne doivent jamais bloquer la livraison en 24h ; elles doivent la protéger.	
Responsabilité	Chaque acteur a un rôle	Chaque acteur sait ce qu'il doit faire, décider ou simplement être informé. La matrice RACI le définit.
Amélioration continue	Apprendre de chaque incident	Chaque incident critique donne lieu à un retour d'expérience (RETEX) pour ne pas répéter les mêmes erreurs.

3

LE RSSI : RÔLE, MISSIONS ET POSITIONNEMENT

Définition

Le **RSSI** — Responsable de la Sécurité des Systèmes d'Information — est la pièce maîtresse de cette gouvernance. Ce n'est pas un technicien qui répare les ordinateurs. C'est le **pilote du risque numérique** de LiZbiZ.

3.1 Positionnement dans l'organigramme

Le RSSI est rattaché directement à la Direction Générale. Cette ligne hiérarchique directe est une condition non négociable du contrôle interne.

Attention

Point clé : le RSSI ne peut pas être subordonné à la DSI. Il doit pouvoir évaluer et critiquer les choix techniques de la DSI en toute indépendance. C'est une condition de base du contrôle interne.

3.2 Les 5 missions du rssi

3.3 Ce que le rssi ne fait pas

Pour éviter toute confusion sur le périmètre du poste :

- Il ne répare pas les ordinateurs — rôle du support IT.
- Il ne développe pas les applications — rôle des équipes techniques de la DSI.
- Il ne décide pas seul des budgets sécurité : il propose, le CODIR valide.
- Il ne remplace pas le DPO sur les sujets de protection des données personnelles.

#	Mission	Description
1	**Définir la politique de sécurité**	**Rédiger et maintenir la politique de sécurité si. Fixer les règles : mots de passe, gestion des accès, télétravail, utilisation des données clients.**
2	**Analyser et piloter les risques**	Identifier les menaces pesant sur LiZbiZ (ransomwares, fuites de données, intrusions). Évaluer leur probabilité et leur impact. Prioriser les actions correctives.
3	**Superviser la réponse aux incidents**	Être le point de contact central en cas d'incident critique. Coordonner les équipes techniques, juridiques et de communication. Activer le plan de continuité si nécessaire.
4	**Assurer la conformité réglementaire**	Veiller au respect du RGPD, PCI-DSS et **[ISO 27001]**. Travailler avec le DPO pour les données personnelles. Préparer les audits.
5	**Sensibiliser et former**	Organiser des formations pour les équipes (phishing, mots de passe, bonnes pratiques). Diffuser une culture de sécurité à tous les niveaux de l'entreprise.

4

LES ACTEURS DE LA GOUVERNANCE

Une gouvernance efficace repose sur des acteurs qui se connaissent et savent quand s'adresser les uns aux autres.

4.1 Les 5 acteurs clés

Acteur	Rôle dans la sécurité	Exemple concret chez LiZbiZ
PDG (Jean-Pierre L.)	Valide la politique de sécurité et les budgets. Représente LiZbiZ en cas de crise publique.	Doit être informé immédiatement si une fuite de données clients est détectée (impact image de marque).
DSI (Sophie M.)	Commanditaire du RSSI. Fournit les ressources techniques. Co-décide des arbitrages.	Valide les budgets pour le renouvellement des certificats SSL et la mise à jour des serveurs.
rssi	Pilote la sécurité au quotidien. Coordonne les incidents. Alerte la direction.	Détecte que les droits ERP d'anciens salariés n'ont pas été révoqués et lance la procédure de nettoyage.
DAF	Évalue l'impact financier des risques. Valide les investissements sécurité.	Estime le coût d'un ransomware (arrêt de production, amendes RGPD) versus le coût d'une assurance cyber.
DPO	Veille à la protection des données personnelles (clients, salariés). Travaille en tandem avec le RSSI.	Notifie la CNIL en cas de fuite des données clients sous 72 heures (obligation RGPD).

4.2 Les instances collectives

Instance	Fréquence	Ordre du jour type
Trimestriel	Tableau de bord sécurité, arbitrage budgétaire, validation de la politique de sécurité.	Comité de Direction (CODIR)
Comité de Sécurité	Mensuel	Suivi des incidents, avancement des projets sécurité, revue des indicateurs.
Cellule de Crise	À la demande	Activation en cas d'incident critique. Coordination PDG, RSSI, DSI, DPO, DAF et communication externe.

5

MATRICE RACI — GESTION DES INCIDENTS CRITIQUES

5.1 Rappel du code raci

Code	Signification	Concrètement
Respons	**Celui qui fait le travail. Il exécute la tâche. Il peut y en avoir plusieurs par activité.**	R
A	**Accountable**	Celui qui **valide** et porte la responsabilité finale. Il n'y en a qu'**un seul** par activité.
C	**Consulted**	Celui qu'on **consulte** avant d'agir. Son avis est nécessaire mais pas décisionnaire.
I	**Informed**	Celui qu'on **informe** après que la décision est prise ou que l'action est faite.

5.2 Périmètre de la matrice

Définition

Un **incident critique** est tout événement qui menace la disponibilité, l'intégrité ou la confidentialité du SI de LiZbiZ : ransomware, fuite de données clients, intrusion avérée, panne majeure de l'ERP.

5.3 Matrice raci — Incidents critiques

5.4 Lecture commentée de la matrice

- **Détecter l'incident (ligne 1) :** c'est le Support IT qui remonte l'alerte (**R**), mais c'est le RSSI qui valide si c'est vraiment critique (**A**). Le PDG est simplement informé.
- **Activer la cellule de crise (ligne 2) :** le PDG décide (**A**), le RSSI exécute et convoque (**R**). Le DAF et le DPO sont informés dès le départ.
- **Notifier la cnil (ligne 5) :** c'est la mission du DPO (**R**), sous la responsabilité du PDG (**A**). Le RSSI est consulté pour les aspects techniques.

Activité	RSSI	DSI	PDG	DAF	DPO	Support IT
1. Détecter et qualifier l'incident	Å	**C**	*I*	—	—	**R**
2. Activer la cellule de crise	**R**	**C**	Å	*I*	*I*	—
3. Contenir l'incident (isolation)	Å	**C**	*I*	—	—	**R**
4. Évaluer l'impact business	**C**	**C**	*I*	Å	**C**	**R**
5. Notifier les autorités (cnil)	**C**	—	Å	—	**R**	—
6. Communiquer en externe	**C**	*I*	Å	**C**	**C**	—
7. Restaurer les systèmes	Å	**C**	*I*	*I*	—	**R**
8. Clôturer et produire le retex	**R**	**C**	*I*	*I*	**C**	**C**
9. Mettre en œuvre les mesures correctives	Å	**R**	*I*	*I*	—	**R**

Table 5.1: Matrice RACI — gestion d'un incident critique chez LiZbiZ

- **Produire le retex (ligne 8) :** le RSSI rédige (**R**) et la DSI et le DPO donnent leur avis (**C**). Tout le monde est informé du résultat.

6

ACTIONS PRIORITAIRES POUR LIZBIZ

Sur la base de l'état des lieux réalisé, voici les 5 chantiers immédiats que le RSSI devra lancer dès sa prise de poste.

Prio.	Action	Délai cible	Pourquoi c'est urgent
Révo les droits erp des anciens collaborateurs	J + 15	Des accès actifs d'ex-salariés représentent un risque immédiat de fuite ou de sabotage interne.	P1
P2	Appliquer les mises à jour sur le serveur web (VLAN 10)	J + 30	Le serveur est exposé à Internet. Les failles non corrigées constituent la première porte d'entrée des ransomwares.
P3	Créer le Comité de Sécurité mensuel	J + 45	Instaurer un rendez-vous régulier pour que la Direction soit informée des risques en temps réel.
P4	Rédiger le Plan de Continuité d'Activité (PCA)	J + 60	LiZbiZ n'a aucun plan formalisé. En cas de ransomware, personne ne sait quoi faire ni dans quel ordre.
P5	Former les 150 salariés aux bonnes pratiques	J + 90	90 % des incidents commencent par une erreur humaine (phishing, mot de passe faible). La formation est l'investissement à meilleur retour.

À retenir

Ces cinq actions couvrent les risques les plus immédiats. Elles n'exigent pas de budget exceptionnel : elles requièrent de la méthode et une autorité claire. C'est précisément le rôle du RSSI de les piloter.

7 ENTRÉE EN VIGUEUR ET VALIDATION

7.1 Conditions d'application

Cette charte entre en vigueur dès sa signature par le Comité de Direction. Elle sera révisée dans deux circonstances :

1. **Révision annuelle** : au minimum une fois par an, en session ordinaire du CODIR, pour vérifier son adéquation avec l'évolution de LiZbiZ.
2. **Révision événementielle** : après tout incident critique ayant mis en évidence une lacune non couverte par ce document.

7.2 Engagements du codir

Cas Pratique — Entreprise LiZbiZ

En approuvant cette charte, le CODIR s'engage à :

- recruter le RSSI en priorité et lui donner les moyens d'agir ;
- respecter la matrice RACI définie au chapitre 5 lors de chaque incident ;
- tenir un Comité de Sécurité mensuel sans exception ;
- réviser cette charte chaque année ou après tout incident critique.

7.3 Tableau de validation

Rôle	Nom	Signature / Visa
Cabinet de Consultants	.....	Présentée par (consultant)
Validée par (dsi)	Sophie M. — DSI	.....
Approuvée par (pdg)	Jean-Pierre L. — PDG	.....

— Fin du document —